MITRE ATLAS | AML.CS0050 - OpenClaw 1-Click Remote Code Execution

Entry Information

ID:
AML.CS0050

Type:
Case-Study

Name:
OpenClaw 1-Click Remote Code Execution

URL:
https://atlas.mitre.org/studies/AML.CS0050/

Incident Date:
2026-02-01

Target:
OpenClaw

Actor:
DepthFirst

Description

A security researcher demonstrated a 1-click remote code execution (RCE) vulnerability to the OpenClaw AI Agent via a malicious link containing a JavaScript script that only takes milliseconds to execute. This vulnerability has been reported and is being tracked to versions of OpenClaw as CVE-2026-25253. [^{\[1\]}][1] OpenClaw “is a personal AI assistant you run on your own devices. It answers you on the chat apps you already use. Unlike SaaS assistants where your data lives on someone else’s servers, OpenClaw runs where you choose – laptop, homelab, or VPS. Your infrastructure. Your keys. Your data.” [^{\[2\]}][2]

The researcher demonstrated that when the victim clicks a malicious link, a client-side JavaScript script is executed on the victim’s browser that can steal authentication tokens from the OpenClaw control interface via a WebSocket connection. It then uses Cross-Site WebSocket Hijacking to bypass localhost restrictions to the OpenClaw Gateway API. Once the connection was established, it uses the stolen token to authenticate and modify the OpenClaw agent configuration to disable user confirmation and escape the container, allowing shell commands to be run directly on the host machine.

[1]: https://nvd.nist.gov/vuln/detail/CVE-2026-25253
[2]: https://openclaw.ai/blog/introducing-openclaw

Attack Procedure:
[AML.T0017] Develop Capabilities: The researcher developed a 1-Click RCE JavaScript script.
[AML.T0079] Stage Capabilities: The researcher staged the malicious script at an inconspicuous website.
[AML.T0011.003] Malicious Link: When the victim clicked the link to the researchers’ website, the malicious JavaScript script executes in the user’s browser.
[AML.T0106] Exploitation for Credential Access: The malicious script opened a background window to the victim’s OpenClaw control interface with the `gatewayUrl` set to a WebSocket address on the researcher’s server. OpenClaw’s control interface trusts the `gatewayUrl` query string without validation and auto-connects on load, sending the Gateway token to the researcher’s server.

[AML.T0107] Exploitation for Defense Evasion: The malicious script performed Cross-Site WebSocket Hijacking (CSWSH) to bypass localhost network restrictions. It opened a new WebSocket connection to the OpenClaw Gateway server on localhost.
[AML.T0012] Valid Accounts: The malicious script used the stolen Gateway token to authenticate, allowing subsequent calls to OpenClaw’s Gateway API on the victim’s system.
[AML.T0081] Modify AI Agent Configuration: The malicious script disabled OpenClaw’s security feature that prompts users before running potentially dangerous commands. This was done by sending the following payload to OpenClaw’s Gateway API:

```
{ "method": "exec.approvals.set",
  "params": { "defaults": { "security": "full", "ask": "off" } }
}
```

[AML.T0105] Escape to Host: The malicious script disabled OpenClaw’s sandboxing, forcing the agent to run commands directly on the host machine instead of inside a docker container. This was done by sending a `config.patch` request to OpenClaw’s Gateway API to set `tools.exec.host` to "gateway".
[AML.T0050] Command and Scripting Interpreter: The malicious script achieved remote code execution by sending a `node.invoke` (OpenClaw’s RPC mechanism) request to OpenClaw’s API.

References

- 1-Click RCE To Steal Your Moltbot Data and Keys (CVE-2026-25253) — https://depthfirst.com/post/1-click-rce-to-steal-your-moltbot-data-and-keys

- CVE-2026-25253 — https://nvd.nist.gov/vuln/detail/CVE-2026-25253